Práctica: Hardening, Módulos Avanzados y Control de Acceso en Apache

Enunciado y Objetivo de la Práctica

Esta práctica consiste en la configuración avanzada, bastionamiento y securización de un servidor web Apache en un entorno Linux local (MAX 12.5). El objetivo principal es aplicar políticas de endurecimiento (hardening) para minimizar la superficie de ataque, implementar control de acceso mediante autenticación HTTP basada en credenciales, y explotar módulos avanzados del servidor como la compresión, la gestión de cabeceras y la reescritura de URLs para optimizar y proteger la infraestructura de una organización simulada.

Competencias de la práctica:

- Endurecimiento de servidores (Hardening): Comprender cómo minimizar la superficie de ataque de un servicio web ocultando información sensible del sistema y deshabilitando métodos HTTP potencialmente peligrosos (como TRACE).
- Control de acceso y autenticación: Saber proteger directorios específicos mediante la combinación de ficheros de control de acceso (.htaccess) y sistemas de credenciales cifradas (htpasswd), simulando entornos reales de administración restringida.
- Gestión de dominios virtuales (VirtualHosts): Entender el funcionamiento de los servidores web basados en nombres, siendo capaces de levantar sitios independientes en entornos locales mediante la manipulación del archivo de resolución de nombres (/etc/hosts).
- Explotación de módulos avanzados: Conocer la utilidad y activación de módulos clave de Apache como mod_rewrite para gestionar redirecciones permanentes (códigos 301), así como la optimización del rendimiento y la seguridad a través de cabeceras.
- Auditoría y verificación mediante herramientas de red: Saber utilizar herramientas de línea de comandos como curl -I para comprobar, validar e interpretar las cabeceras HTTP devueltas por el servidor, asegurando que las políticas de seguridad se están aplicando correctamente.

Esquema de la Arquitectura y Seguridad Implementada

[Navegador / Cliente Web]

|

(HTTP / Puerto 80)

▼

[Servidor Apache (MAX 12.5)]

├── 🗀 /var/www/seguro (VirtualHost: seguro.empresa.local)

│ ├── 🔒 /admin (Protegido por .htaccess + .htpasswd)

│ └── 🔄 /viejo ➡ Redirección 301 a /nuevo (mod_rewrite)

└── 🌓 Hardening Global (ServerTokens Prod, ServerSignature Off, TraceEnable Off)

Paso 0: Comprobación de la Instalación del Servidor Apache

En un terminal:

sudo systemctl status apache2

Si está instalado saldrá el servicio como ***active (running)***

Si no está instalado

Abre una terminal en tu sistema MAX 12.5 y asegúrate de tener Apache instalado y activo:

sudo apt update

sudo apt install -y apache2 apache2-utils

sudo systemctl enable --now apache2

Paso 1: Configurar el VirtualHost `seguro.empresa.local`

1. Crea la estructura de directorios raíz y de prueba:

   sudo mkdir -p /var/www/seguro/admin

   sudo mkdir -p /var/www/seguro/nuevo

   echo "<h1>Sitio seguro de la empresa skynet</h1>" | sudo tee /var/www/seguro/index.html

   echo "<h1>Zona de Administracion</h1>" | sudo tee /var/www/seguro/admin/index.html

   echo "<h1>Pagina nueva (Redireccion)</h1>" | sudo tee /var/www/seguro/nuevo/index.html

2. Crea el archivo de configuración del VirtualHost:

   sudo nano /etc/apache2/sites-available/seguro.empresa.local.conf

   Pega el siguiente contenido:

```
<VirtualHost *:80>
    ServerName seguro.empresa.local
    DocumentRoot /var/www/seguro
```

```
        <Directory /var/www/seguro>
            Options Indexes FollowSymLinks
            AllowOverride All
            Require all granted
        </Directory>
        ErrorLog ${APACHE_LOG_DIR}/seguro_error.log
        CustomLog ${APACHE_LOG_DIR}/seguro_access.log combined
    </VirtualHost>
```

3. Habilita el sitio y añade la resolución local en el fichero `/etc/hosts`:

sudo a2ensite seguro.empresa.local.conf

sudo systemctl reload apache2

echo "127.0.0.1 seguro.empresa.local" | sudo tee -a /etc/hosts

Paso 2: Hardening Global del Servidor (`security.conf`)

1. Edita el archivo de configuración de seguridad global:

sudo nano /etc/apache2/conf-available/security.conf

2. Configura los parámetros clave para ocultar información al atacante y deshabilitar métodos vulnerables:

ServerTokens Prod

ServerSignature Off

TraceEnable Off

3. Valida la sintaxis y recarga el servicio:

sudo apache2ctl configtest

sudo systemctl reload apache2

Paso 3: Proteger la Carpeta `/admin` con Autenticación HTTP Básica

1. Genera el fichero de credenciales cifradas y crea un usuario administrador (ej. `admin_user`):

   sudo htpasswd -c /etc/apache2/.htpasswd_seguro admin_user

   (Introduce la contraseña cuando se solicite).

2. Crea el fichero de control de acceso dentro de la carpeta protegida:

   sudo nano /var/www/seguro/admin/.htaccess

   Pega las siguientes directivas:

   AuthType Basic

   AuthName "Acceso Restringido - Area de Administracion"

   AuthUserFile /etc/apache2/.htpasswd_seguro

   Require valid-user

Paso 4: Habilitar Módulos Avanzados y Configurar Redirecciones

1. Activa los módulos necesarios en Apache:

   sudo a2enmod rewrite headers deflate

   sudo systemctl reload apache2

2. Configura la regla de reescritura de URLs en la raíz creando un fichero `.htaccess`:

   sudo nano /var/www/seguro/.htaccess

   Añade el siguiente bloque:

   <IfModule mod_rewrite.c>

   RewriteEngine On

   RewriteRule ^viejo/?$ /nuevo/ [R=301,L]

   </IfModule>

Paso 5: Comprobaciones de Seguridad y Evidencias (`curl -I`)

Ejecuta los siguientes comandos desde la terminal para verificar el correcto funcionamiento y documentar las evidencias:

- **Comprobar Hardening (ServerTokens Prod):**

curl -I http://seguro.empresa.local

Evidencia: La cabecera `Server: Apache` no muestra versiones de OS ni módulos internos.

- **Comprobar bloqueo del método TRACE:**

  curl -X TRACE -I http://seguro.empresa.local

  Evidencia: Debe retornar un código de error `405 Method Not Allowed`.

- **Comprobar protección de la zona de administración:**

  curl -I http://seguro.empresa.local/admin/

  Evidencia: Retorna un código `401 Unauthorized` exigiendo credenciales o HTTP/1.1 405 Method Not Allowed

- **Comprobar redirección 301 (mod_rewrite):**

  curl -I http://seguro.empresa.local/viejo

  Evidencia: Retorna código `301 Moved Permanently` apuntando hacia `/nuevo/`.